

MaGMa 2.0

Use case framework



MaGMa UCF 2.0



Versie	1.0
Datum	25.09.2026
Auteur	Rob van Os

Inhoud

1	Introductie	3
1.1	Ontwikkelingen	3
1.2	Is MaGMA UCF nog relevant?	3
2	MaGMA 1.0 - samenvatting	5
2.1	Model	5
2.2	MaGMA - Management	6
2.3	MaGMA - Growth	6
2.3.1	Aanbrengen van richting	7
2.3.2	Aanbrengen van prioriteit	7
2.4	MaGMA - Metrics & assessment	8
3	MaGMA 2.0	9
3.1	Model	9
3.1.1	Unified Kill Chain	10
3.1.2	Berekeningen	10
3.2	Management & Growth	12
3.3	Metrics & assessment	12
3.4	Samenhang	14
3.4.1	Risico analyse	15
3.4.2	Visibility	15
3.4.3	Detectiekwaliteit	16
3.5	Huidige beperkingen	17
4	PRISMA Tool	19
4.1	PRISMA tool componenten	19
4.2	Opslaan en exporteren	20
5	Annex A: DeTT&CT data kwaliteit indicatoren	21
	Annex B: PRISMA tool visualisaties	22
	DeTT&CT heatmap	22
	DeTT&CT Insights	23
	MaGMA L1, L2, L3	24
	MaGMA heatmap	25
	MaGMA Insights	26
	MaGMA summary	26

1 Introductie

In 2017 werd het MaGMA use case framework (UCF) geïntroduceerd. Dit raamwerk was het resultaat van een samenwerking tussen verschillende financiële instellingen binnen de FI-ISAC die security monitoring use cases wilden uitwisselen tussen hun security operations centers (SOCs). Na de initiële publicatie in 2017 is het raamwerk echter niet meer onderhouden.

1.1 Ontwikkelingen

In de afgelopen 10 jaar zijn er belangrijke ontwikkelingen geweest die een weerslag hebben op de actualiteit van het MaGMA raamwerk. De voornaamste ontwikkelingen zijn:

- **De doorontwikkeling van het MITRE ATT&CK® framework**, met name als zelfstandige methodologie voor 'defensive gap analysis': het in kaart brengen van de huidige stand van detectie ten opzichte van de gewenste situatie.
- **Ontwikkeling van uitgebreidere kill chains**, zoals de unified kill chain, die de Lockheed Martin kill chain samen brengt met MITRE ATT&CK® en een veel meer gedetailleerde aanvalsketen kan weergeven. Bij de Lockheed Martin kill chain is een heel groot deel van de aanval 'actions on objectives'.
- **Hoge mate van automatisering binnen SOC processen**. De originele versie van MaGMA UCF leunde op het bijhouden van een Excel file. Dit is niet meer passend in een modern security operations center.

1.2 Doelstelling MaGMA UCF

De doelstelling van het MaGMA Use Case Framework is het inzichtelijk maken van de kwaliteit van monitoring. Hiermee kan voorkomen worden dat monitoring is ingericht, maar niet voldoende effectief is in het detecteren van dreigingen, waardoor incidenten ontstaan die voorkomen hadden kunnen worden. Met de uitkomsten van MaGMA metingen (en DeTTeCT metingen) kunnen roadmaps opgesteld worden, prioriteiten gesteld worden, en investeringskeuzes gemaakt worden. Hier kan verbetering van monitoring gerealiseerd worden, alsook adressering van mogelijk blinde vlekken of algehele tekortkomingen in infrastructurele zichtbaarheid vanuit cyber security perspectief. Het uiteindelijke doel is het kwantificeerbare maken en verbeteren van cyberweerbaarheid binnen het SOC.

1.3 Is MaGMA UCF nog relevant?

Een belangrijke vraag om te stellen is of MaGMA UCF in de huidige tijd van AI en automatisering in een security operations center en een sterke focus op MITRE ATT&CK® voor het vaststellen van volledigheid van detecties. Ondanks deze ontwikkelingen is het belangrijk om vast te stellen dat de kernprincipes van MaGMA nog steeds van toepassing zijn in een modern security operations center. Zonder use case management ontbreekt de grotere context van detecties in security monitoring, en blijft detectie in het technische vlak zitten. Use case management geeft vorm aan de koppeling van detecties aan bedrijfsdoelstellingen, en MaGMA is, met de principes en het model, nog steeds van waarde. MaGMA 2.0 is een geüpdatete variant van het MaGMA UCF die past binnen een modern security operations center.

Voor organisaties waarbij de detectie sterk gedreven wordt door gestandaardiseerde agents met beperkte configuratiemogelijkheden is use case management nog steeds relevant, maar detection engineering (het zelf maken en onderhouden van detectieregels) minder. In een dergelijke opzet zal de toepassing van MaGMA UCF minder toegevoegde waarde hebben. De

waarde van MaGMA is vooral zichtbaar wanneer het SOC team zelf detecties ontwikkelt en verbetert. Zonder detectie engineering, blijft nog wel de koppeling met risico's relevant. Ook organisaties die een SOC uitbesteden kunnen baat hebben bij de toepassing van MaGMA voor de set aan detecties die beschikbaar is gesteld voor de organisatie. Hiermee wordt inzichtelijk hoeveel toegevoegde waarde security monitoring heeft voor de organisatie.

2 MaGMa 1.0 - samenvatting

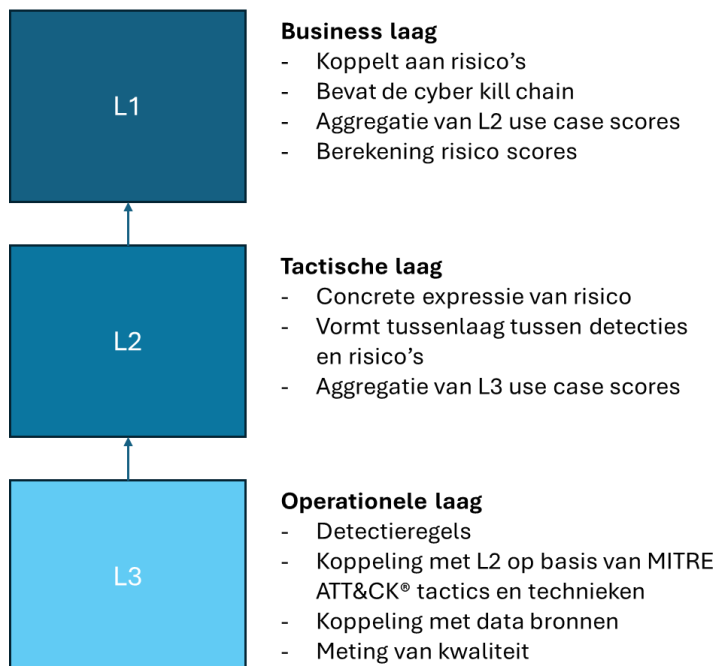
MaGMa is een afkorting van **M**anagement, **G**rowth, **M**etrics and **a**ssessment. Deze 3 componenten beschrijven de belangrijkste elementen van het raamwerk. Daarnaast is ook het MaGMa model belangrijk om te begrijpen, met name de gelaagdheid. In dit hoofdstuk wordt de basis van MaGMa 1.0 toegelicht. Meer informatie is te vinden in het originele document en het whitepaper [1].

2.1 Model

Het belangrijkste aan het MaGMa model is dat use cases benaderd worden in 3 lagen:

- **De business / risico laag (L1).** Deze laag beschrijft het bedrijfsrisico wat door middel van de use case gemonitord wordt. Deze laag is essentieel om operationele security monitoring te kunnen koppelen aan risico's en concrete waarde voor de organisatie. In de originele versie van MaGMa bestond de business laag uit geaggregeerde scores voor elke fase in de Lockheed Martin kill chain, aangevuld met specifieke risico's waar een directe koppeling op L2/L3 mogelijk was.
- **De tactische laag (L2).** Deze laag beschrijft op welke manier het risico beschreven in L1 zich kan manifesteren. Deze laag is op 1 lijn gebracht met de Tactics uit MITRE ATT&CK®, en uitgebreid met logische groepen die niet gerelateerd zijn aan MITRE tactieken.
- **De detectie laag (L3).** Deze laag omvat de technische detectie regels waarmee de monitoring uitgevoerd wordt. Waar van toepassing wordt op deze laag de MITRE ATT&CK® koppeling gemaakt. Ook wordt op de L3 laag de meting (zie Metrics & assessment) uitgevoerd.

Hieronder is een versimpeld model weergegeven van MaGMa. Een uitgebreider model is te vinden in de originele documentatie.

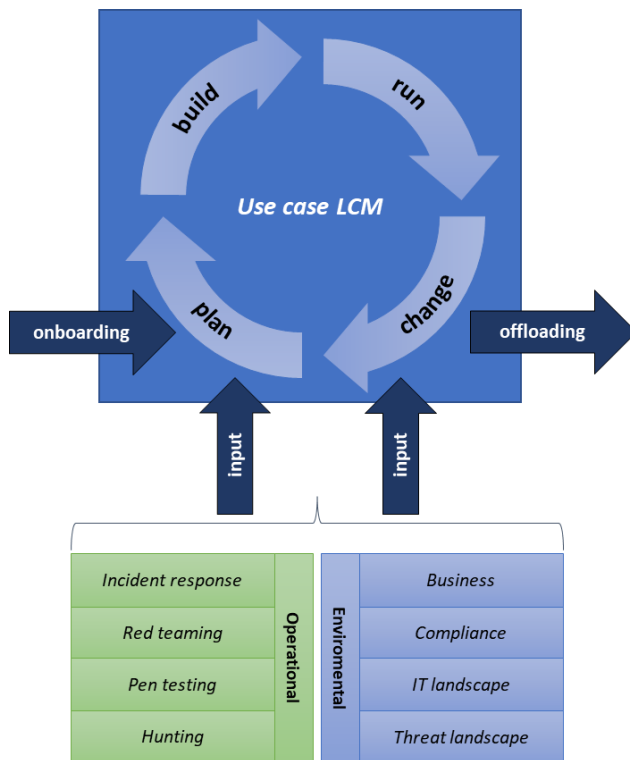


Figuur 1: versimpeld MaGMa model

¹ [MaGma](#)

2.2 MaGMa - Management

Het eerste element van MaGMa beschrijft het managen van de use case gedurende de gehele life-cycle: van de initiële opzet van de use cases, tot regelmatig onderhoud, en uiteindelijk ook het buiten gebruik stellen van use cases die niet langer noodzakelijk zijn. Dit wordt als volgt gevisualiseerd in MaGMa:



Figuur 2: MaGMa life-cycle management

Binnen het LCM is het met name van belang om de juiste inputs te identificeren: operationele inputs (verbeterinitiatieven voortkomend uit operationele security werkzaamheden) en omgevingsfactoren (zowel intern als extern). Deze inputs zorgen voor het bijhouden van de bestaande set aan use cases, en het aanmaken van nieuwe use cases als de bestaande detectie niet volstaat.

2.3 MaGMa - Growth

Het tweede element van het MaGMa UCF is growth. MaGMa heeft hier geen specifieke aanpak voor gedefinieerd. In plaats daarvan wordt aangegeven over welke assen groei in volledigheid / volwassenheid gerealiseerd kan worden. Dat zijn de volgende assen:

- **Breedte van de ruleset (horizontale as).** Hiermee wordt bedoeld hoe compleet je ruleset is. Daarbij kan gebruik gemaakt worden van de structuur van MaGMa; maar ook MITRE ATT&CK® volledigheid is een uitstekende manier om de volledigheid van de ruleset te waarborgen. Bedenk daarbij wel dat sub-technieken in MITRE ATT&CK® vanuit monitoring oogpunt unieke technieken zijn, met unieke data bronnen. Een combinatie van MaGMa en MITRE ATT&CK® zorgt ervoor dat ook use cases die niet of niet volledig leunen op aanvalstechnieken uit MITRE ATT&CK® meegenomen worden in het overzicht.
- **Diepte van de ruleset (verticale as).** Hiermee wordt bedoeld in hoeverre de use case in kan gaan op verschillende variaties of verschijningsvormen van de aanval die

gedetecteerd wordt binnen de use case. Een belangrijke vraag hierbij is: “wanneer is goed, goed genoeg?”. Een regel met voldoende diepte is effectief op het detecteren van de aanval, ook wanneer de aanvalstechniek op een andere manier wordt uitgevoerd. Bijvoorbeeld vanuit een ander domein, een ander IP adres, een andere filename, een andere file locatie, etc. Goede detecties richten zich op de kern van de techniek, die hetzelfde blijft, ongeacht de verschijningsvorm van de aanval [2].

Om groei op een beheerste manier uit te voeren is het noodzakelijk om goede richting te bepalen, en de juiste prioriteiten te stellen.

2.3.1 Aanbrengen van richting

Zoals aangegeven is het mogelijk om over 2 assen de volledigheid van de set aan use cases te laten groeien. Er zijn verschillende strategieën die gehanteerd kunnen worden:

- **Uitsluitend horizontale groei.** In dit geval ligt de focus op het uitbreiden van de regels zodat de volledigheid ten aanzien van een vastgesteld raamwerk behaald wordt. De gemiddelde diepte (verticale as) per regel gaat wat achteruit in deze strategie. Dit is hiernaast gevisualiseerd.
- **Uitsluitend verticale groei.** In dit geval ligt de focus op het verdiepen van de ruleset, en het kunnen detecteren van verschillende variaties van aanvalstechnieken. Ook hier geldt dat de gemiddelde breedte per diepte laag wat achteruit gaat in deze strategie, hiernaast gevisualiseerd.
- **Een combinatie van horizontale en verticale groei.** In dit geval wordt gekeken naar welke regels prioriteit hebben, en wordt gekozen voor verbreding of verdieping wanneer dit passend is voor de doelstellingen. Met deze strategie wordt in twee richtingen tegelijk ontwikkeld, zoals hiernaast weergegeven. Deze strategie heeft als voorwaarde dat de organisatie in staat is om deze prioriteit aan te brengen.



2.3.2 Aanbrengen van prioriteit

Prioriteit aanbrengen in het laten groeien van de set aan use cases kan op verschillende manieren ingestoken worden. De basis daarbij is steeds anders:

- **Op basis van dreigingen.** Hierbij kan gekeken worden naar welke dreigingsactoren zich richten op de geografie, sector, en mogelijk de organisatie zelf. Daarnaast kan in kaart gebracht worden welke aanvalstechnieken het meest gebruikt worden. Deze aanvalstechnieken, en de use cases waarin ze passen dienen de meeste aandacht te krijgen. *MITRE ATT&CK*², gecombineerd met actuele cyber threat intelligence (CTI) spelen een centrale rol in deze prioriteitstelling.
- **Op basis van de huidige maatregelen.** De huidige set aan maatregelen, zowel technisch als niet-technisch vormt de basis voor weerbaarheid van de organisatie tegen cyberaanvallen. Technieken maken veelal misbruik van het ontbreken van maatregelen, het niet goed geconfigureerd zijn van maatregelen, of het niet up-to-date (gepatchet) zijn van maatregelen. Door in kaart te brengen welke maatregelen bestaan, en wat de

² [Summitting the Pyramid v4.0.0 — Summitting the Pyramid v4.0.0 documentation](#)

kwaliteit is van deze maatregelen, wordt het beschermingsprofiel van de organisatie duidelijk. Daarmee wordt ook evident welke aanvalstechnieken waarschijnlijk het meest effectief zullen zijn. *MITRE DEF3ND™* speelt een centrale rol in deze prioriteitstelling.

- **Op basis van de huidige data bronnen.** In een grote of complexe organisatie is het vaak lastig de juiste data te ontvangen, met de juiste kwaliteit. Dit geldt ook voor managed security service providers die afhankelijk zijn van wat de klant aanlevert, en wat de contractuele afspraken daaromtrent zijn. De kwaliteit en volledigheid van data bepaalt uiteindelijk welke monitoring mogelijkheid bestaan. *DeTT&CT* speelt een centrale rol in deze prioriteitstelling.

De meest gerichte aanpak is die aanpak waarbij gericht wordt op actuele dreigingen, waar bestaande maatregelen niet afdoende zijn, en de data beschikbaar is. In de praktijk kan dit een complexe aanpak zijn. Het startpunt moet altijd zijn: inzicht in de meest gebruikte technieken. Deze informatie is voorhanden uit de MITRE ATT&CK® data set. Vanuit dit startpunt kan naar behoefte meer nuance toegevoegd worden met de andere elementen, om tot een meer volledige aanpak te komen.

2.4 MaGMa - Metrics & assessment

De derde en laatste component van MaGMa is Metrics en assessment. Deze component is er op gericht om de kwaliteit van de set aan use cases inzichtelijk te maken. Daarbij zijn 3 metrics gedefinieerd: coverage, implementation, effectiveness. Vervolgens zijn daar 2 berekende waarden van afgeleid: weight en potential. In het volgende hoofdstuk worden deze metrics in het nieuwe model beschreven, omdat ze afwijken van de interpretatie in de originele MaGMa. Naast kwaliteitsanalyse met de MaGMa metrics is het ook mogelijk om detectie kwaliteit te meten met DeTT&CT. Daarvoor worden echter andere kwaliteitscriteria gebruikt. In dit document worden alleen de MaGMa criteria gehanteerd.

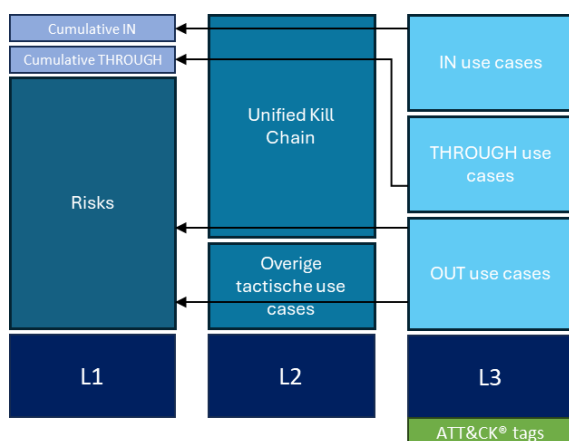
3 MaGMA 2.0

Versie 2.0 van MaGMA adresseert de tekortkomingen genoemd in de introductie. Daarnaast wordt ook een andere manier van het aggregeren en berekenen van waarde geïntroduceerd die risico-specifieker is en meer aansluit bij hoe risico's zich manifesteren. Dit hoofdstuk volgt dezelfde structuur als het vorige hoofdstuk om de verschillen duidelijk te maken.

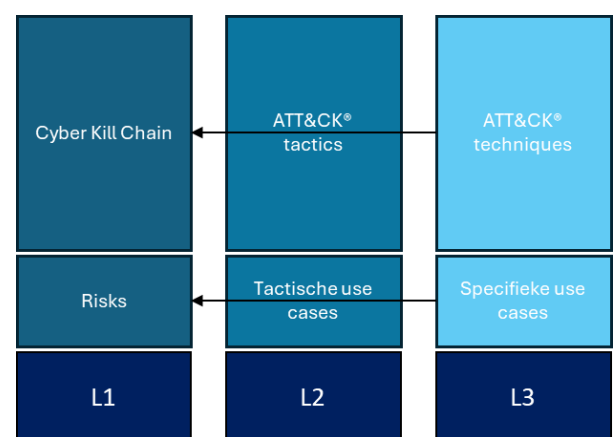
3.1 Model

In de kern is het MaGMA model niet veranderd: de 3 lagen zijn intact gebleven. De invulling van de lagen is net anders, met name in de L1 laag (business laag). Waar in het originele MaGMA model de cyber kill chain een prominente rol speelde die los stond van de risico's, is in MaGMA 2.0 gekozen voor een model waar de unified kill chain in is opgenomen, en is geïntegreerd in de risico berekeningen.

Het MaGMA 2.0 model is hieronder weergegeven (links), met daarnaast het MaGMA 1.0 model (rechts) ter vergelijking.



Figuur 3: MaGMA 2.0 model



Figuur 4: MaGMA 1.0 model

Wanneer MaGMA 2.0 vergeleken wordt met MaGMA 1.0 vallen een aantal zaken op:

1. De L3 laag maakt nu onderscheid in use cases op basis van de unified kill chain fasen: IN, THROUGH en OUT. Voorheen was er alleen een onderscheid tussen specifieke en niet-specifieke use cases.
2. De L2 laag aggregereert de unified kill chain en vormt een bredere basis dan de ATT&CK® tactics. Dit omdat de unified kill chain ook tactics bevat die niet terug komen in MITRE ATT&CK®. Daarnaast blijft ruimte behouden voor niet-killchain gerelateerde use cases (zoals beleidsovertredingen en compliance-gerelateerde zaken). Dit laatste stuk is niet veranderd ten opzichte van MaGMA 1.0
3. Risico's hebben een veel groter aandeel in L1 dan in het vorige model, waar met name de cyber kill chain een grote rol speelde. In de praktijk zorgde dat ervoor dat de kwaliteitsscores vaak voor meer dan 90% uitkwamen in 1 van de fasen van de cyber kill chain, en het grootste deel daarvan weer in 'actions on objectives'. In het nieuwe model is de rol van risico's nadrukkelijker aanwezig, en worden de scores voor use cases die niet specifiek zijn voor een risico meegenomen in de weging.

Deze wijzigingen zorgen ervoor dat het nieuwe model meer representatief is voor het daadwerkelijke risico en rekening kan houden met de fasen van een aanval.

3.1.1 Unified Kill Chain

Zoals aangegeven is de unified kill chain een centraal onderdeel geworden van de MaGMA 2.0 opzet. De unified kill chain beschrijft een aanval in 3 fasen en 19 stappen, zoals afgebeeld in onderstaande figuur:



Figuur 5: unified kill chain (bron: *The Unified Kill Chain, raising resilience against advanced cyber attacks* [3])

Het idee achter het minder prominent koppelen aan de kill chain op de L1 laag van MaGMA is dat voor een groot deel van de killchain (alles binnen de IN fase, alles binnen de THROUGH fase, deels binnen de OUT fase), nog niet bepaald kan worden wat het uiteindelijke doel is van de aanvaller. Dat wordt pas zichtbaar aan het einde van de kill chain. Daarmee zou je detecties kunnen opdelen in 2 verschillende typen:

- **Early detection.** Vroege detectie van aanvallen, terwijl het doel nog niet bereikt is door de aanvaller. Dit is feitelijk het grootste deel van de aanval voor vele typen aanvallen.
- **Impact detection.** Detectie van het daadwerkelijke doel van de aanval. Dat kan zijn: detectie van versleuteling van bestanden (ransomware), exfiltratie van gevoelige informatie (data theft), ongeautoriseerde toegang tot hoog-geclassificeerd intellectueel eigendom (espionage), etc.

Binnen MaGMA 2.0 wordt een geaggregeerde score toegekend aan IN, en THROUGH. Voor OUT wordt een directe koppeling gemaakt met L1 risico's (via specifieke tactics in de L2 laag) waar mogelijk en zinvol.

3.1.2 Berekeningen

In MaGMA 2.0 zijn 2 soorten berekeningen van toepassing:

- **Aggregatie.** Aggregatie is feitelijk het bij elkaar optellen van individuele resultaten, beginnend bij L3 niveau. Aggregatie vindt plaats op L2 niveau door de resultaten van geassocieerde L3 regels bij elkaar op te tellen. Ook vindt aggregatie plaats op L1 niveau, zowel voor de risico's als voor de eerste 2 fasen van de unified kill chain. Deze worden benoemd als: Cumulative IN, en Cumulative THROUGH.
- **Calculatie.** Voor de risico's vindt daarnaast een berekening plaats. Per risico is deze berekening specifiek gemaakt door de bepalen wat de verhouding is tussen IN, THROUGH, en OUT. Deze verhouding is anders bij een DDoS aanval, dan bij een ransomware aanval.

³ [Unified Kill Chain: Raising Resilience Against Cyber Attacks](#)

De aggregatie is eenvoudig, automatisch, en niet te configureren. De calculatie is wel te configureren, voor elk gedefinieerd risico. De configuratie heeft impact op de uiteindelijke risico score. De calculatie die in MaGMA 2.0 gebruikt wordt is de volgende:

Risico = 100% - ((cumulative IN * IN weight) + (cumulative THROUGH * THROUGH weight) + (aggregated OUT * OUT weight))

3.1.2.1 Voorbeeld berekening: DDoS

Op het eerste gezicht lijkt de calculatie complex. Daarom worden 2 voorbeelden gegeven. Het eerste voorbeeld is DDoS. Voor elke calculatie moet de verhouding IN – THROUGH – OUT bepaald worden. Deze verhouding wordt uitgedrukt in percentages, tot een totaal van 100%. Bij het risico DDoS ligt de verhouding bijvoorbeeld als volgt:

- **IN:** 5%. Slechts een klein deel van de aanval is IN (initial compromise). Alleen reconnaissance valt hier onder.
- **THROUGH:** 0%. Omdat er geen sprake is van digitale inbraak, is de THROUGH fase niet van toepassing op dit risico.
- **OUT:** 95%. Het grootste deel van de aanval is directe impact op de online dienstverlening door het uitvoeren van de DDoS aanval.

Als we in dit rekenvoorbeeld uitgaan van een cumulatieve IN score van 40%, een cumulatieve THROUGH score van 35%, en de score van de regels specifiek voor DDoS detectie van 85%, kunnen we het risico als volgt berekenen:

$$\text{Risico} = 100\% - ((40\% * 5\%) + (35\% * 0\%) + (85\% * 95\%)) = 17\%$$

Dit betekent een 17% risico dat er geen detectie plaatsvindt van dit risico (zowel in de vroege fase als in de eindfase). Dat risico is dus relatief laag, en wordt met name beïnvloedt door de specifieke detectie van de DDOS impact.

Noot: 40% en 35% voor respectievelijk cumulative IN en TROUGH zijn relatief lage scores. Dit betekent dat voor deze organisatie het algemene detectieniveau laag is. Dat kan dus komen door slechte zichtbaarheid of dekkingsgraad, slecht getunede regels, niet-gevalideerde regels, of een combinatie van al deze factoren.

3.1.2.2 Voorbeeld berekening: ransomware

Bij ransomware wordt veelal wel de volledige kill chain gevolgd. Bij dit risico ligt de verhouding bijvoorbeeld als volgt:

- **IN:** 25%. Een belangrijk deel van de aanval is initial compromise. Op dat moment is nog niet duidelijk dat het om een ransomware aanval gaat: het doel is nog onbekend.
- **THROUGH:** 45%. Om uiteindelijk de belangrijkste systemen te kunnen versleutelen is laterale beweging noodzakelijk, en toegang tot de juiste credentials. Dit vormt het langste deel van de aanval, en krijgt daardoor ook het grootste percentage. Ook hier is het nog niet duidelijk wat het doel is van de aanval.
- **OUT:** 30%. Het laatste deel van de verhouding wordt hier toegekend aan de OUT fase. Deze bestaat uiteraard uit het versleutelen van kernsystemen (impact), maar wordt meestal vergezeld door exfiltration (en mogelijk collection) van informatie voor meervoudige afpersing.

Als we in dit rekenvoorbeeld uitgaan van dezelfde cumulatieve IN en THROUGH scores als het vorige rekenvoorbeeld, en de regels specifiek voor ransomware en daaraan gelieerde detectie van exfiltratie op 65%, kunnen we het risico als volgt berekenen:

$$\text{Risico} = 100\% - ((40\% * 25\%) + (35\% * 45\%) + (65\% * 30\%)) = 55\%$$

Dit betekent een significant risico dat er geen detectie plaatsvindt op deze aanval. In tegenstelling tot het verbeteren van DDOS monitoring uit de vorige berekening, waarbij vooral de specifieke use cases een hoge impact hebben op de totaalscore, moet de organisatie met name inzetten op het verbeteren van de algemene kwaliteit van monitoring voor de THROUGH fase om dit risico te verkleinen.

3.2 Management & Growth

Wat betreft use case life cycle management en de groei van de use case library is in het nieuwe model geen verandering. De basis blijft hier hetzelfde. De beschrijving die gegeven is in het vorige hoofdstuk is ook voorzien van recentere inzichten in dit onderwerp.

3.3 Metrics & assessment

In MaGMA 2.0 is opnieuw gekeken naar de metrics, met name omdat deze lastig te automatiseren waren. Binnen het nieuwe model zijn dezelfde metrics gebleven, maar zijn ze net wat anders geïnterpreteerd. Een belangrijk uitgangspunt bij de definitie van de nieuwe metrics is dat ze geschikt moeten zijn voor automatisering. Daarnaast wordt het volgende basisprincipe gebruikt: een detectieregel functioneert goed als deze de juiste data heeft, accuraat is, en getest is op correcte werking onder verschillende omstandigheden.

Met dit basisprincipe zijn de metrics als volgt gedefinieerd:

- **Coverage.** Ook wel bekend als visibility. Deze metric geeft aan in hoeverre het SOC beschikt over volledige informatie om de detectie correct uit te kunnen voeren. Coverage kan op 2 lagen van detail worden benaderd:
 - **Hoog niveau.** Hierbij wordt eenvoudig gekeken naar welk percentage van de betreffende assets / data sources aangesloten is op de monitoring omgeving. Dat kan automatisch door een vergelijking te maken tussen de aanwezigen bronnen en het totaal aan bronnen volgens de CMDB. Een voorwaarde daarbij is wel dat de CMDB representatief is voor de omgeving. Het hebben van een volwaardig en volwassen asset management proces is hierbij een belangrijke voorwaarde. Zonder een dergelijk proces mist het beeld op de volledigheid van maatregelen (waaronder monitoring) en ontstaan hoog-risico blinde vlekken.
 - **Detail niveau.** Hierbij wordt naar coverage gekeken door middel van het in kaart brengen van visibility met behulp van DeTT&CT. DeTT&CT kan per platform inzichtelijk maken welke aanvalstechnieken gedetecteerd kunnen worden op basis van de aanwezigheid van de juiste informatie (data components in MITRE ATT&CK®). De volledigheid van de informatie hangt bijvoorbeeld af van de configuratie van logging. Het is ook mogelijk om een kwaliteitsdimensie hier aan toe te voegen. DeTT&CT onderscheidt 5 verschillende data kwaliteit indicatoren. Standaard worden deze niet gebruikt in de DeTT&CT metingen. Het is in ieder geval aan te raden om “device completeness” mee te nemen. Daarmee wordt een combinatie verkregen van asset coverage met gedetailleerde visibility. De

volledige beschrijving van de DeTT&CT data kwaliteit indicatoren is opgenomen als annex A.

Coverage / visibility wordt uitgedrukt als een percentage. Concreet: 100% op deze metric betekent dat alle data sources zijn aangesloten (coverage) of dat alle data components aanwezig zijn (visibility). Wanneer DeTT&CT gebruikt wordt, kan het percentage overgenomen worden, door de techniek te koppelen aan de detectieregel op basis van MITRE ATT&CK®. Als meerdere technieken gedetecteerd worden, dient de DeTT&CT output van beide technieken gecombineerd te worden tot 1 percentage (gemiddelde).

- **Implementation.** Implementatie beschrijft hoe goed de regel geïmplementeerd is in de tooling. Deze metric is opnieuw geïnterpreteerd als de false positive ratio van de regel. Als de regel veel false positives geeft, dan krijgt deze een lage score.

Detectie logica	Malicious / non-malicious	Uitkomst	Beschrijving
Correct	Malicious	True positive	Detectie van een echt security incident
Correct	Non-malicious	Benign positive	Detectie van een security event met een legitieme reden (bv. pen test, administratieve handeling, etc.)
Incorrect	Malicious	False negative	Een echt incident dat niet gedetecteerd is door foutieve (of incomplete) detecties
Incorrect	Non-malicious	False positive	Een alert die niet gegenereerd had moeten worden

Concreet wordt de metric uitgedrukt als een percentage van alerts dat aangemerkt is als false positive, vergeleken met het totaal aantal alerts voor die detectieregel. Het is ook mogelijk om de *benign positives* mee te nemen, omdat met tuning of allow listing dergelijke meldingen soms ook voorkomen kunnen worden.

Indien detectie regels geen meldingen hebben gehad in de afgelopen periode (dit is mogelijk bij zeer specifieke alerts), kunnen deze als 100% worden geïnterpreteerd (geen false positives). Regels waarvan verwacht wordt dat ze met regelmaat af gaan, vallen hier uiteraard niet onder. Belangrijk bij dit type regels is dat goed getest wordt op de correctheid van de regel: effectiveness. Effectiveness meten wordt hierna toegelicht.

- **Effectiveness.** Effectiviteit wordt bepaald door hoe klein de kans is op false negatives: het niet zien van een aanvalstechniek, omdat de regel niet klopt of niet volledig is. Om de kans op false negatives te verminderen is het belangrijk om testen uit te voeren op de correctheid van de regel (detectie validatie). Detectie validatie kan verschillende vormen hebben, van volledig handmatig tot grotendeels geautomatiseerd met speciaal daarvoor ontwikkelde tools.

Voor de score wordt de volgende tabel gebruikt:

Percentage	Beschrijving
20%	Ongeteste regel
30%	Getest op bestaande data gedurende ontwikkeling en/of release
40%	Getest en reactief geüpdatet op basis van feedback van analisten
60%	Getest gedurende ontwikkeling en updates, af en toe testen met gesimuleerde data (log injectie)
95%	Getest gedurende ontwikkeling en updates, reguliere testen door een red teams en andere typen aanvalssimulatie (event generatie)
100%	Regelmatig getest door red teams, gebruik makend van geautomatiseerde tooling (zoals Breach & Attack Simulation (BAS) tooling) met variaties van technieken

Naast de voorgaande 3 basis metrics, kent MaGMA ook 2 metrics die berekend worden op basis van deze metrics: weight en potential.

- **Weight.** Weight is de totale score van de detectieregel is wordt berekend door een vermenigvuldiging van de percentage van de hiervoor genoemde 3 metrics. Het resultaat van deze berekening is opnieuw een percentage:

$$weight = visibility (\%) * implementation (\%) * effectiveness (\%)$$

Omdat vermenigvuldiging van percentages uitgevoerd wordt, valt de score voor een detectieregel snel laag uit wanneer één van de metrics een lage waarde heeft.

Bijvoorbeeld: als alle kwaliteitsindicatoren een score van 75% hebben, is de totale score slechts 42% (75% van 75% van 75%).

- **Potential.** Potential geeft aan hoeveel de regel verbeterd kan worden. Hoe hoger de potential waarde, hoe meer verbetering mogelijk is. In tegenstelling tot potential in MaGMA 1.0, is potential in MaGMA 2,0 een inverse waarde van weight:

$$potential = 100\% - weight$$

Deze waarde kan gebruikt worden voor het prioriteren van verbeterinitiatieven. Dat kan gedaan worden door eenvoudig de regels met de meeste potential eerst aan te pakken. Ook is het mogelijk meer risico-gebaseerd te werken door eerst te identificeren welke regels het meest belangrijk zijn voor de organisatie.

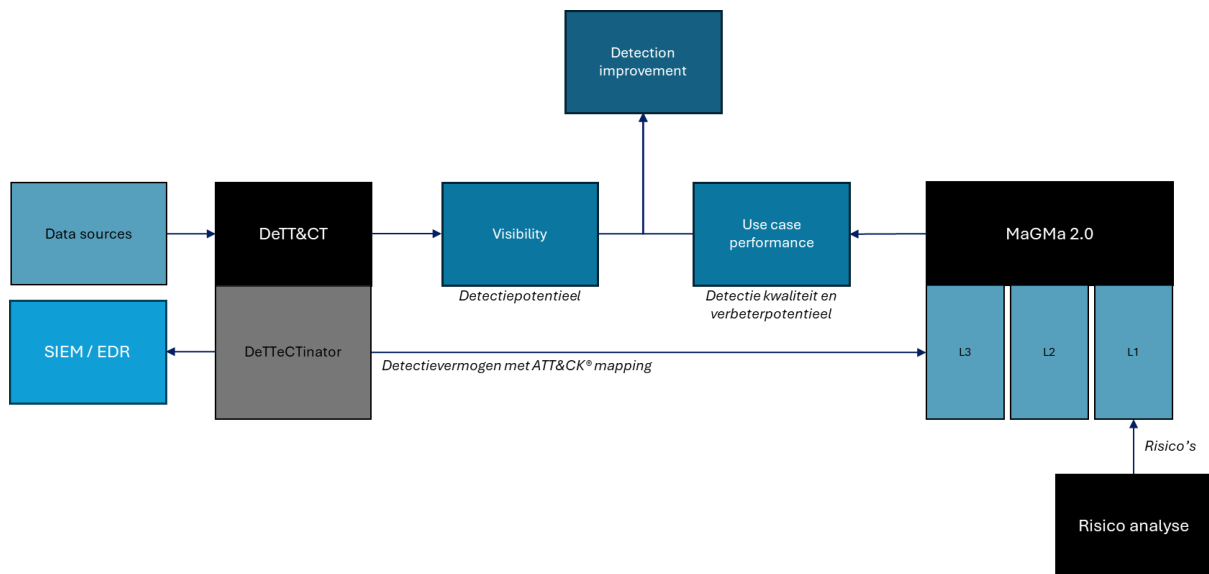
Belangrijk om te benoemen is dat deze metrics voor de verschillende MITRE ATT&CK® domeinen inzichtelijk gemaakt kunnen worden. Zo kan een aparte score bepaald worden voor het ICS (OT) domein, om ook een specifiek verbeterplan te maken voor de kwaliteit en volledigheid van monitoring binnen het domein.

3.4 Samenhang

In MaGMA 2.0 is een duidelijke samenhang aanwezig tussen verschillende activiteiten:

- Het in kaart brengen van risico's (risico analyse)
- Het in kaart brengen van visibility (DeTT&CT)
- Het in kaart brengen van detectie kwaliteit (MaGMA)

Deze samenhang is in onderstaand figuur getoond.



In de totstandkoming van MaGMA 2.0 zijn de MaGMA / DeTT&CT metingen gecombineerd met SOC-CMM metingen. Zo ontstaat een integraal beeld van zowel volwassenheid (maturity) in de breedte van het SOC als bekwaamheid (capability) in de diepte, specifiek op het niveau van security monitoring en daaraan gekoppelde detection engineering activiteiten. In een SOC-CMM meting worden ook onderwerpen behandeld zoals use cases management (mogelijk in te vullen met MaGMA), visibility (mogelijk in te vullen met DeTT&CT), en detection engineering (onderliggend aan de ontwikkeling van detectieregels en het beheersen van detectie en data kwaliteit).

3.4.1 Risico analyse

Risico analyses zijn de belangrijkste input op het L1 niveau van MaGMA. Met behulp van de risico analyse worden risico's in kaart gebracht waar security monitoring ingezet kan worden als middel om het risico te verkleinen. Het betreft hier zowel algemene cyber security risico's (zoals ransomware en DDoS), maar ook organisatie-specifieke risico's, zoals het saboteren van operationele technologie, het stelen van intellectueel eigendom, of het inzien en/of publiceren van vertrouwelijke gegevens. Voor elk L1 risico geldt dat er Lw en L3 use cases zijn die rechtstreeks gekoppeld kunnen worden. Daarnaast is algemene staat van monitoring ook een factor.

3.4.2 Visibility

Visibility wordt per platform (bv: Windows servers of Windows endpoints) in kaart gebracht met behulp van DeTT&CT. Het is daarbij belangrijk om te realiseren dat DeTT&CT op een groot detailniveau werkt. Gedetailleerd inzicht in de configuratie van de databronnen is hierbij noodzakelijk. De DeTT&CTinator tool is hierbij ondersteunend op 2 manieren:

- Het uitlezen van data sources om de visibility in kaart te brengen. Deze output kan gebruikt worden als metric op het L3 niveau.
- Het uitlezen van de SIEM om de detectieregels in kaart te brengen. Deze output kan gebruikt worden om het L3 niveau te voorzien van detectieregels en ATT&CK® mappings.

Hiermee kan de tool ondersteunend zijn in het automatiseren van metingen.

3.4.3 Detectiekwaliteit

De detectiekwaliteit wordt met MaGMA gemeten zoals eerder in dit hoofdstuk beschreven. Daarmee wordt duidelijk hoe goed de set aan detectieregels presteert. Door deze informatie te koppelen aan de visibility informatie, wordt inzichtelijk op welke manier de set aan detectieregels verbeterd kan te worden.

De PRISMA tool (volgende hoofdstuk) koppelt DeTT&CT en MaGMA aan elkaar waar mogelijk. Dit geeft de hoogste graad van automatisering. Zoals aangegeven in paragraaf 3.3 wordt algemene dekkingsgraad op basis van de CMDB gebruikt, wanneer geen DeTT&CT gegevens voorhanden zijn. Ook het berekenen van deze dekkingsgraad kan in verregaande mate geautomatiseerd worden.

3.5 Totstandkoming

Net zoals MaGMA 1.0 is ook MaGMA 20 op een coöperatieve manier tot stand gekomen. Voor de ontwikkeling van het model is een cross-sectorale werkgroep opgericht. De input uit deze werkgroep is gebruikt in het vormgeven van het nieuwe model en de methodologie daarachter, alsook het verifiëren van de relevantie van de uitkomsten. Naast het opstellen van het model en de methodiek is ook een pilot uitgevoerd, om te zien of de theorie ook goed vertaald kan worden naar de praktijk. Deze pilot is uitgevoerd met meerdere security operations centers van de Rijksoverheid.

De ontwikkeling van de PRISMA tool is met financiering van de Rijksoverheid uitgevoerd. Voor de Rijksoverheid is het belang van het continu verhogen van de cyberweerbaarheid van strategisch belang. Daarbij is het ook overheidsbeleid om open standaarden en open source tools te omarmen en het gebruik daarvan te stimuleren.

4 Beperkingen en best practices

4.1 Huidige beperkingen

In de huidige implementatie van MaGMA 2.0 en PRISMA zijn er een aantal beperkingen geïdentificeerd:

1. De huidige PRISMA tool is nog niet geschikt om in bulk data te importeren. Ook zijn er beperkte mogelijkheden tot handmatige (bulk) bewerkingen. Om deze reden wordt er tevens een Excel importfile bijgeleverd, waarin de initiële bulk imports mee gedaan kunnen worden. Deze Excel file ondersteunt alleen Enterprise ATT&CK® technieken (dus geen mobile of ICS).
2. MaGMA biedt op dit moment geen ondersteuning voor detectieregels die op meerdere MITRE tactics of techniques te mappen zijn. Dit kan het geval zijn bij 'multi-stage' detecties. In deze gevallen dient een detectieregel opgesplitst te worden in meerdere MaGMA L3 use cases, met elk hun eigen link naar een L2.
3. Er is beperkte mogelijkheid om niet-traditionele SIEM detectieregels weer te geven. Denk hierbij aan EDR, maar ook aan UEBA. Op dit moment is hier nog geen oplossing voor.
4. Het is niet mogelijk om verschillende scopes aan DeTT&CT en MaGMA metingen tegelijkertijd weer te geven in PRISMA. Dat betekent dat er altijd maar 1 DeTT&CT meting actief is die gekoppeld kan worden aan use cases (visibility).
5. Het is niet mogelijk om een bepaalde metric voor een use case uit te zetten. Mocht er bijvoorbeeld geen data zijn over false-positives van een bepaald use case, dan moet deze op 100% gezet worden. Dit vanwege de weight berekening die percentages met elkaar vermenigvuldigt. Met een waarde van 0% wordt het eindresultaat (weight) altijd 0%.
6. De PRISMA tool gebruikt MITRE ATT&CK® versie 17.1. De aanpassingen die nodig zijn om versie >18 compatible te zijn, zijn nog niet doorgevoerd.
7. Het is momenteel niet mogelijk om eigen threat actoren toe te voegen aan de lijst; alleen de standaard actoren worden ondersteund.
8. Het is niet mogelijk om een weging toe te passen op individuele detectieregels (L3 niveau). Dit betekent dat alle L3 regels even belangrijk zijn en even zwaar meetellen in de totaalscore.
9. De tool ondersteunt geen multi-select voor use cases. Meerdere waardes tegelijk aanpassen, meerdere regels verwijderen, etc. zijn daarmee niet mogelijk. Bij grote hoeveelheden use case is het handig om gebruik te maken van de Excel file voor het voorbereiden van de regels.

Verdere doorontwikkeling van de tool is noodzakelijk om deze beperkingen te adresseren.

4.2 Best practices voor het uitvoeren van een meting

De volgende best practices zijn geïdentificeerd tijdens het uitvoeren van de pilot:

- Een MaGMA UCF meting dient te worden voorafgegaan door een gesprek over de reikwijdte van het SOC. Bij grote hoeveelheden OT en IT moet per technologiedomein (IT, OT) een deels separate meting worden gedaan.
- DeTT&CT metingen kosten veel tijd om uit te voeren. Het is daarom belangrijk om goed te kiezen welke platformen (bijvoorbeeld: Windows clients, Linux servers) in kaart te brengen voor wat betreft hun visibility.

- Bij MaGMA metingen moet soms gewerkt worden met inschattingen als de juiste data niet voorhanden is. Het is belangrijk om expliciet te maken dat er sprake is van een inschatting, en wat (bij benadering) de betrouwbaarheid is van de inschattingen.
- Alle keuzes die gemaakt worden tijdens het uitvoeren van een meting, zoals de scope van DeTTeCT, het wel of niet meenemen van use cases zonder MITRE mapping, en hoe er omgegaan is met multi-stage detecties, moeten goed vastgelegd worden. Daarmee ontstaat verantwoording over de resultaten, en herhaalbaarheid van de metingen.
- Wanneer er onvoldoende tijd is om individuele regels te beoordelen (bijvoorbeeld voor de test strategie) kan het zinvol zijn om use case categorieën te maken, en voor deze categorieën als geheel een score toe te kennen. In de tool betekent dit concreet dat alle use cases binnen een categorie dezelfde waarde toegekend krijgen. De tool ondersteunt geen categorieën, dus dit zal buiten PRISMA uitgewerkt moeten worden.
- Waar mogelijk moet gewerkt worden met DeTTeCT scores, omdat deze een hoger detailniveau kennen dan inschattingen of berekeningen van asset coverage door middel van asset management tooling.
- Tijd en detailniveau staan vaak recht tegenover elkaar, ook in deze metingen. Bepaal vooraf waar de focus ligt. Daarmee kan vastgesteld worden waar het hoogste detail niveau gehaald moet worden, en waar een lager niveau van detail ook voldoende is. Ook deze keuzes worden gedocumenteerd.
- De losse Excel file kan gebruikt worden voor het automatisch koppelen van L3 regels aan L2 regels. Daarnaast is het eenvoudiger om use cases massaal te bewerken en te organiseren in de Excel tool. Het juiste voorwerk voordat de import uitgevoerd wordt, kan veel tijd achteraf schelen.
- Werk zoveel mogelijk met geautomatiseerde metrics. Alles wat handmatig gedaan moet worden maakt het proces bewerkelijk en minder herhaalbaar. Als dat betekent dat er concessies gedaan moeten worden aan het detailniveau van de metric kan dat acceptabel zijn. Deze beslissing moet genomen worden op SOC management niveau of hoger.

5 PRISMA Tool

Om de methodologie te ondersteunen is de Prioritized Risk Indicator for Security Monitoring & Analysis (PRISMA) tool ontwikkeld. Deze tool geeft inzicht en sturing aan detectie engineers en management.

5.1 PRISMA tool componenten

De tool kent 2 hoofdcomponenten:

1. **DeTT&CT visualisaties.** De PRISMA tool kan de YAML files van DeTT&CT inlezen en daar direct een visualisatie van maken. Met deze visualisatie is het direct inzichtelijk hoe de visibility scores zijn ten opzichte van de MITRE ATT&CK® framework. Voor de verschillende verschijningsvormen van ATT&CK® (enterprise, mobile, ICS), wordt een overzicht getoond.

Ook biedt dit deel van de tool de mogelijkheid om te filteren. Door deze filters toe te passen kan:

- gekeken worden naar specifieke actoren (en de technieken die zijn gebruiken)
- gefilterd worden op specifieke technieken
- gefilterd worden op specifieke data components
- gefilterd worden op scoringspercentages voor visibility en occurrence (hoe vaak een techniek gebruikt wordt door aanvallers)

Tenslotte bevat dit deel van de tool ook een sectie INSIGHTS. Deze insights kunnen gebruikt worden om sturing te geven aan visibility. De insights omvatten:

- Visibility scores per tactic van MITRE ATT&CK®
- Statistieken uit de ATT&CK® data set, waaronder totale aantallen technieken en sub technieken, meest capabele aanvallers, meest voorkomende technieken, etc.
- Suggesties voor verbetering. In deze grafiek wordt aangegeven welke data component de meeste toegevoegde waarde heeft voor het verbeteren van visibility voor het gemeten platform.

Een belangrijke kanttekening is dat DeTT&CT per platform werkt, en dus geen algemene score geeft voor de gehele infrastructuur. Op dit moment ondersteunt de tool 1 staat per keer; er kunnen dus niet meerdere scores voor verschillende platformen in 1 keer ingeladen worden.

2. **MaGMA visualisaties.** Dit deel van de tool is direct ondersteunend aan de MaGMA methodiek. Door de L1, L2, en L3 laag te definiëren en in te laden kunnen de berekeningen in de tool gebruikt worden om tot geaggregeerde en berekende scores te komen. Deze scores kunnen vervolgens gebruikt worden om de detectie te verbeteren. Als een DeTT&CT YAML file is ingeladen, kan deze gekoppeld worden aan de L3 rules. Wanneer de DeTT&CT score over een ander platform gaat dan de use cases (bv: de DeTT&CT score is berekend voor de Windows endpoints, maar de use case betreft Linux servers), kan de koppeling verbroken worden.

Naast het basis deel met daarin de use cases, de metrics, de scores, en de berekeningen zoals beschreven in het vorige hoofdstuk bevat dit deel van de tool ook visualisaties, te weten een heatmap en insights.

De heatmap is een weergave van het MITRE ATT&CK® framework, met de scores van de individuele regels daarin verwerkt. De basis daarvoor zijn de L3 use cases, met MITRE ATT&CK® koppelingen. Ook hier kan gefilterd worden op specifieke groepen, of op het score percentage.

De insights geven een samenvatting van de MaGMA scores, en helpen om de volgende stappen te kunnen zetten. De volgende inzichten worden gegeven:

- Aantal use cases per laag (L1, L2, L3). Dit is een weergave van de distributie van de use cases.
- Per data source de gemiddelde visibility (coverage), implementation, en effectiveness. Met deze inzichten kan in kaart gebracht worden over en bepaalde data sources zijn (bijvoorbeeld: windows servers, firewalls, of de cloud omgeving) die achter blijven in detectiekwaliteit en meer aandacht nodig hebben.
- Meest voorkomende aanvalstechnieken in de detectie ruleset
- L3 use cases met de hoogste improvement potential
- Per L1 use case het improvement potential uitgebeeld. Zo kan per risico gekeken worden of het vooral zinvol is om te investeren in uitbreiden van de zichtbaarheid (coverage / visibility), tuning van de regels (implementation) of testen van de regels (effectiveness)

Met deze inzichten wordt de kwaliteit van de set aan detecties over verschillende assen duidelijk gemaakt, en wordt ook inzichtelijk waar de sturing op moet liggen om de risico's naar een acceptabel niveau te brengen.

Voorbeelden van de visualisaties zijn toegevoegd aan dit document als annex B.

5.2 Opslaan en exporteren

De tool bevat veel informatie. Wat betreft DeTT&CT wordt gebruik gemaakt van de standaard DeTT&CT YAML files. Deze kunnen gegenereerd worden met de daarvoor bedoelde tool, of via een andere geautomatiseerde wijze (waaronder DeTT&CTinator). Wat betreft MaGMA kan de status zowel opgeslagen als ingelezen worden in een YAML formaat. Het importeren van gegevens in de tool kan gedaan worden door middel van een ondersteunende Excel file, waarin de use cases op verschillende niveaus aan elkaar gekoppeld worden.

Meer uitleg hierover is te vinden in de technische documentatie van de PRISMA tool.

6 Annex A: DeTT&CT data kwaliteit indicatoren

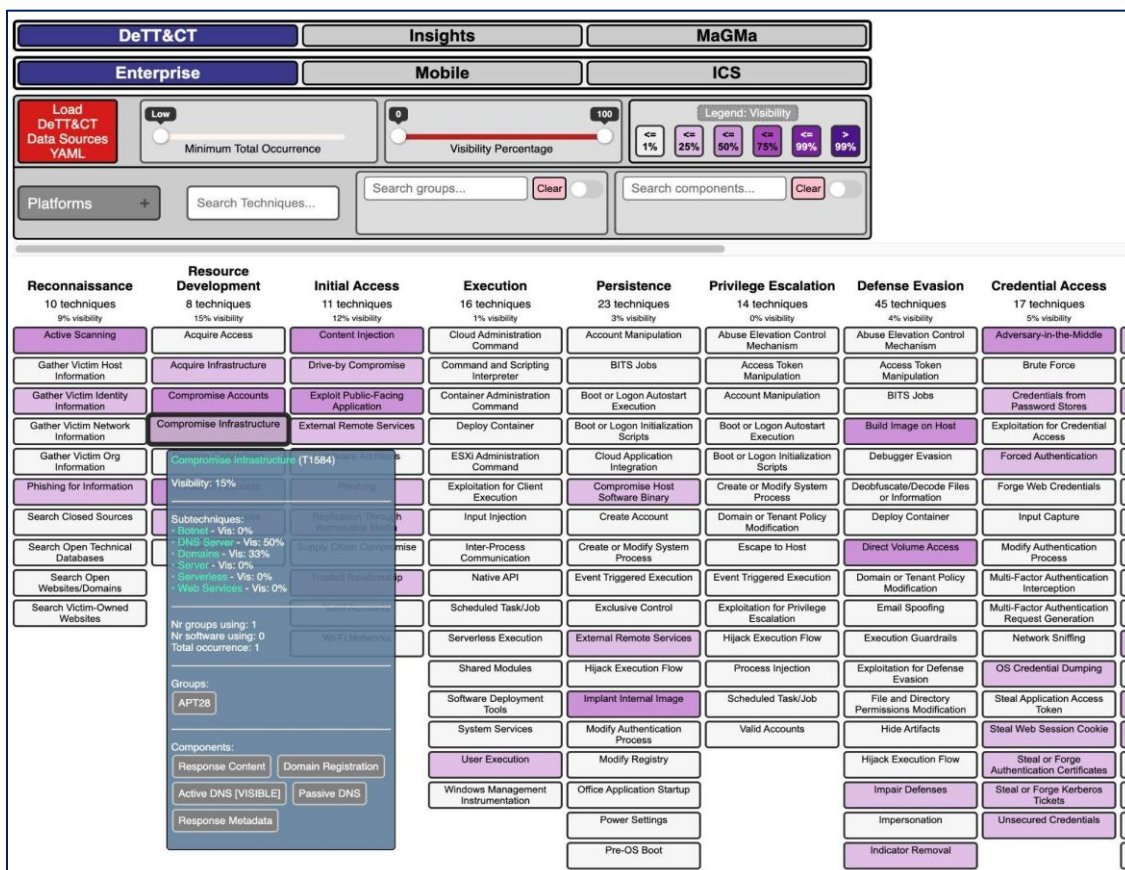
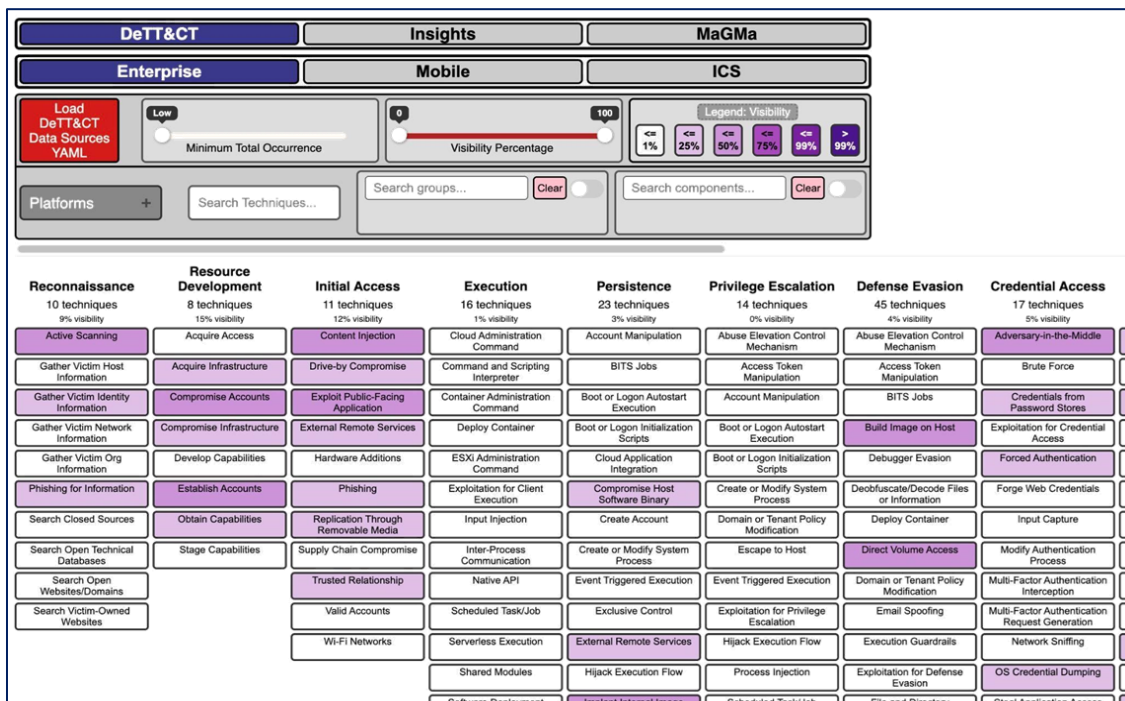
De volgende tabel geeft de beschrijving weer van de DeTT&CT data kwaliteit indicatoren. De tekst is niet vertaald uit het Engels.

Indicator	Beschrijving	Vraagstelling	Voorbeeld
Device completeness	Indicates if the required data is available for all devices.	When doing a hunting investigation can we cover all devices/users that we need to?	We are missing event data for endpoints running an older version of Windows.
Data field completeness	Indicates to what degree the data has the required information/fields, and to what degree those fields contain data.	Are all the required data fields in the event present and contain data to perform my investigation?	We have proxy logs, but the events do not contain the "Host" header.
Timeliness	Indicates when data is available, and how accurate the timestamps of the data are in relation to the actual time an event occurred.	Is the data available right away when we need it? Do the timestamps in the data represent the time the record was created or ingested?	We have a delay of 1-2 days to get the necessary data from all endpoints into the security data lake. Timestamps are representing not the time an event occurred, but ingestion time in the security data lake.
Consistency	Says something about the standardisation of data field names and types.	Can we correlate the events with other data sources? Can we run queries across all data sources using standard naming conventions for specific fields?	Field names within this data source are not in line with that of other data sources.
Retention	Indicates how long the data is stored compared to the desired data retention period.	For how long is the data available? How long do you want to keep the data?	Data is stored for 30 days, but we ideally want to have it for 1 year.

Annex B: PRISMA tool visualisaties

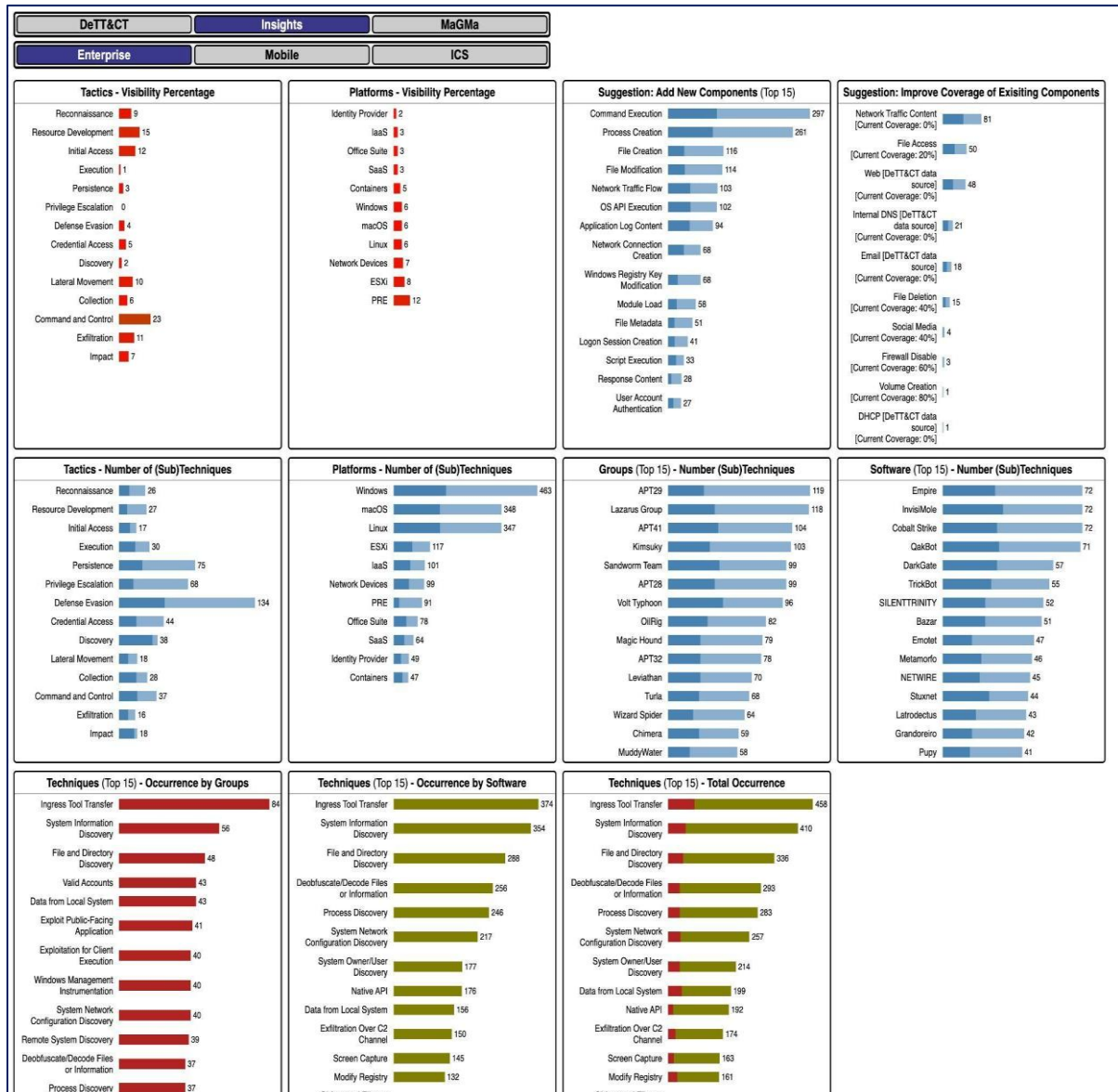
DeTT&CT heatmap

Onderstaande figuur toont de DeTT&CT heatmap met de bijbehorende filter mogelijkheden, met daaronder een heatmap waarin de details voor 1 techniek zichtbaar gemaakt zijn.



DeTT&CT Insights

Onderstaande figuur toont de insights die voortkomen uit een DeTT&CT meting



MaGMa L1, L2, L3

Hieronder worden respectievelijk de L1, L2, en L3 niveaus getoond.

DeTT&CT			Insights		MaGMa								
Enterprise			Mobile		ICS								
L1	L2	L3	Heatmap	Insights	Summary	Load MaGMa YAML	Save MaGMa YAML						
ID	Use Case Name	Description	L2 UC Related	L3 UC Related	Visibility %	Implementation %	Effectiveness %	Weight %	Potential %	IN Impact %	THR Impact %	OUT Impact %	Risk
IN	Cumulative IN risk	Cumulative risk of IN stages and techniques, serving as a risk amplifier for the business risks.	4	33	55.72	23.64	53.62	15.11	84.89				
THR	Cumulative THROUGH risk	Cumulative risk of THROUGH stages and techniques, serving as a risk amplifier for the business risks.	34	133	57.59	33.82	54.03	23.12	76.88				
DOS	Denial of Service	Any Denial of Service attack, optionally distributed with the goal of causing outages.	1	6	0.00	0.00	0.00	0.00	100.00	80	10	10	85.60
ESP	Espionage / Data Theft	Corporate espionage aimed at stealing proprietary intellectual property.	77	253	27.35	18.40	32.80	12.67	87.33	30	40	30	82.42
CEO	CEO Fraud	Attempts by criminals to impersonate the organization's CEO or other board-level executive and	12	27	0.00	0.00	0.00	0.00	100.00	60	20	20	86.31
EXT	Extortion / Ransomware		6	28	0.00	0.00	0.00	0.00	100.00	40	20	40	89.33
SAB	Sabotage / Destruction	Any action to destroy/damage organizational and personal asset, information or reputation with the	18	82	45.63	27.08	39.58	17.81	82.19	30	50	20	80.34
INS	Insider Threat		4	7	0.00	0.00	0.00	0.00	100.00	20	40	40	87.73
POL	Policy Violations	Illegal sites, service account usage, presence of vulnerabilities, Unauthorized	64	93	0.00	0.00	0.00	0.00	100.00	30	40	30	86.22
Averages →					20.70	11.44	20.00	7.64	92.36				
+ ADD NEW USE CASE +													

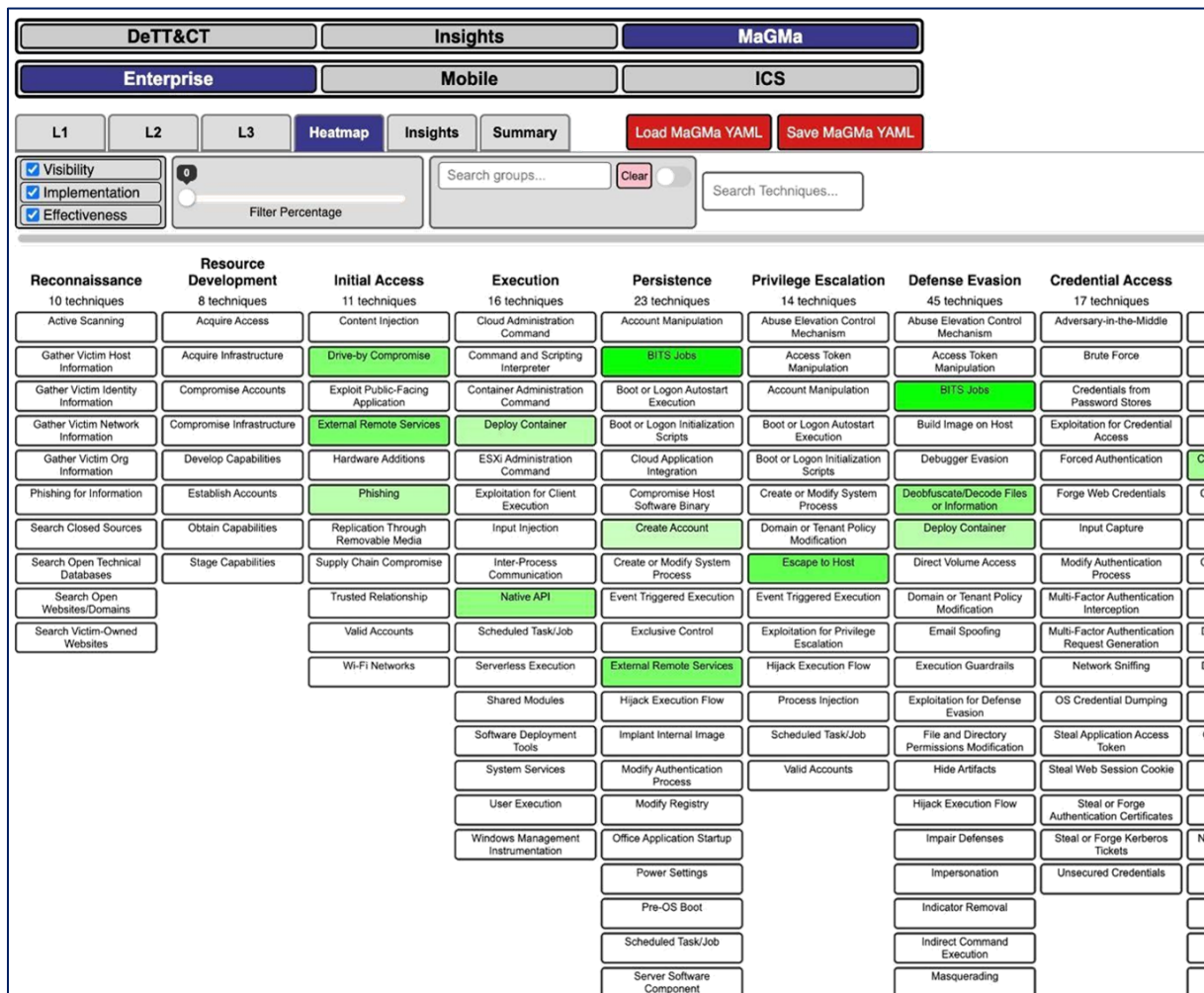
DeTT&CT		Insights		MaGMa								
Enterprise		Mobile		ICS								
L1	L2	L3	Heatmap	Insights	Summary	Load MaGMa YAML		Save MaGMa YAML				
	ID	Use Case Name	Description		Parent Use Case	L3 UC Related	Viability %	Implementation %	Effectiveness %	Weight %	Potential %	
	IN-REC	Reconnaissance			IN Cumulative IN risk	↘	3	51.80	20.00	90.00	5.94	94.06
	IN-RES	Resource development			IN Cumulative IN risk	↘	12	85.00	48.33	86.67	36.45	63.55
	IN-DEL	Delivery			IN Cumulative IN risk	↘	4	0.00	0.00	0.00	0.00	100.00
	IN-SOC	Social Engineering			IN Cumulative IN risk	↘	8	0.00	0.00	0.00	0.00	100.00
	IN-EXP	Exploitation			IN Cumulative IN risk	↘	9	90.67	60.00	74.00	37.80	62.20
	IN-PER	Persistence			IN Cumulative IN risk	↘	3	92.40	47.60	78.00	31.43	68.57
	IN-DEF	Defense Evasion			IN Cumulative IN risk	↘	5	93.40	25.09	81.32	16.82	83.38
	IN-CNC	Command & Control			IN Cumulative IN risk	↘	59	88.26	11.74	72.61	7.75	92.25
	IN-PHY	Physical compromise			IN Cumulative IN risk	↘	23	0.00	0.00	0.00	0.00	100.00
	THR-PIV	Pivoting	Tunneling traffic through a controlled system to other systems that are not directly accessible		THR Cumulative THROUGH risk	↘	18	0.00	0.00	0.00	0.00	100.00
	THR-DIS	Discovery	Techniques that allow an attacker to gain knowledge about a system and its network environment.		THR Cumulative THROUGH risk	↘	2	82.75	53.33	80.00	34.35	65.65
	THR-PRI	Privilege Escalation	The result of techniques that provide an attacker with higher permissions on a system or network.		THR Cumulative THROUGH risk	↘	11	0.00	0.00	0.00	0.00	100.00
	THR-EXE	Execution	Techniques that result in execution of attacker-controlled code on a local or remote system.		THR Cumulative THROUGH risk	↘	27	87.44	53.59	89.49	43.92	56.08

DeTT&CT			Insights		MaGMa								
Enterprise			Mobile		ICS								
L1	L2	L3	Heatmap	Insights	Summary		Load MaGMa YAML	Save MaGMa YAML					
	ID	Use Case Name	Description	Parent Use Case	Data Source	ATTACK Technique	Override	Visibility %	Implementation %	Effectiveness %	Weight %	Potential %	
	IN-DEF-1	1		IN-DEF: Defense Evasion	Example DS 1	T1653: Power Settings			0.00	42	87	0.00	100.00
	IN-PER-1	2		IN-PER: Persistence	Example DS 1	T1020: Automated Exfiltration			54	54	84	24.49	75.51
	IN-DEF-2	3		IN-DEF: Defense Evasion	Example DS 1	T1621: Multi-Factor Authentication Request Generation			43	100	56	24.08	75.92
	IN-PER-2A	4 - A		IN-PER: Persistence	Example DS 2	T1020: Automated Exfiltration			12	43	32	1.65	98.35
	IN-PER-2B	4 - B		IN-PER: Persistence	Example DS 2	T1621: Multi-Factor Authentication Request Generation			54	76	78	32.01	67.99
	IN-DEF-3	5		IN-DEF: Defense Evasion	Example DS 3	T1005: Data from Local System			76	45	100	34.20	65.80
	THR-EXE-1	6		THR-EXE: Execution	Example DS 3	T1649: Steal or Forge Authentication Certificates			2.66	36	36	0.37	99.63
	IN-PER-3	7		IN-PER: Persistence	Example DS 3	T1653: Power Settings			67	84	12	6.75	93.25
	IN-DEF-4	8		IN-DEF: Defense Evasion	Example DS 3	T1025: Data from Removable Media			0.00	76	23	0.00	100.00
	IN-DEF-05	9		IN-DEF: Defense Evasion	Example DS 3	T1659: Content Injection			12	85	82	8.36	91.64
	THR-CRE-1A	10 - A		THR-CRE: Credential Access	Example DS 4	T1049: System Network Connections Discovery			22	0	36	0.00	100.00
	IN-PER-4A	11 - A		IN-PER: Persistence	Example DS 4	T1656: Impersonation			54	23	75	9.32	90.69
	IN-PER-4B	11 - B		IN-PER: Persistence		T1008: Exploitation for Privilege Escalation			87	12	37	3.86	96.14

Op L3 niveau is de koppeling met DeTT&CT zichtbaar. Waar geen vinkje staat wordt de DeTT&CT score gebruikt. Ook is de koppeling met ATT&CK® door middel van tags zichtbaar gemaakt.

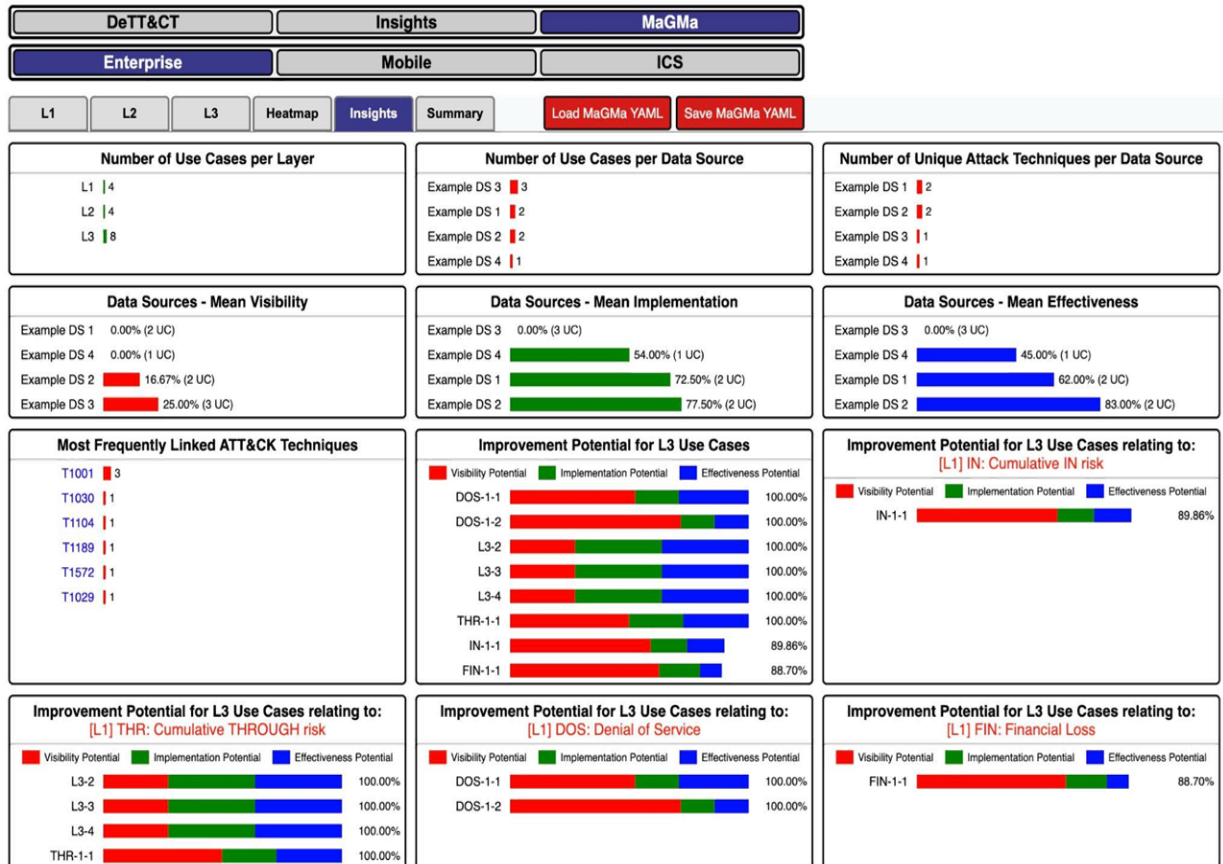
MaGMa heatmap

Onderstaande heatmap wordt gegenereerd op basis van de informatie op L3 niveau en de koppeling van L3 use cases met MITRE ATT&CK® door het toevoegen van tags.



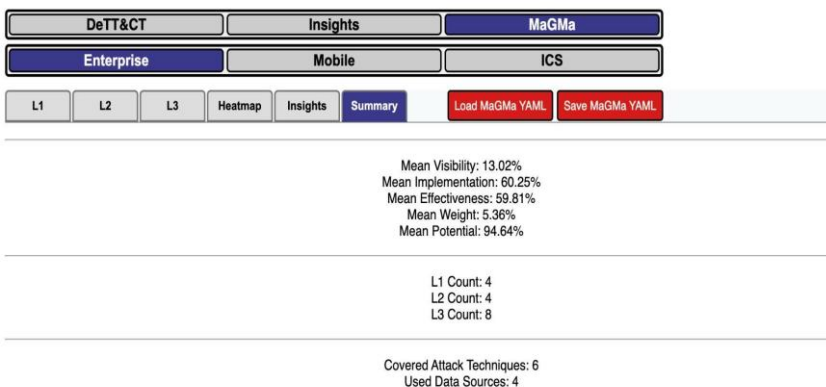
MaGMa Insights

Onderstaande de MaGMa insights: algemeen, per data source, en per L1 use case



MaGMa summary

Tenslotte de MaGMa summary: het overzicht met totale scores.



MaGMa 2.0

Use case framework

This publication is licensed under a Creative Commons BY-SA 4.0 License

You are free to:

- **Share** — copy and redistribute the material in any medium or format for any purpose, even commercially.
- **Adapt** — remix, transform, and build upon the material for any purpose, even commercially.
- The licensor cannot revoke these freedoms as long as you follow the license terms.

Under the following terms:

- **Attribution** — You must give appropriate credit, provide a link to the license, and indicate if changes were made. You may do so in any reasonable manner, but not in any way that suggests the licensor endorses you or your use.
- **ShareAlike** — If you remix, transform, or build upon the material, you must distribute your contributions under the same license as the original.
- **No additional restrictions** — You may not apply legal terms or technological measures that legally restrict others from doing anything the license permits.

For the full license description, see:

<https://creativecommons.org/licenses/by-sa/4.0/>